

Tema 6

Schema de răspuns la un atac MITM și planul de acțiune

Schema de răspuns la un atac Man-In-The-Middle (MITM)

1. Detectia atacului

Detectia unui atac MITM este esențială pentru a minimiza impactul acestuia asupra rețelei și a utilizatorilor. Un prim pas este monitorizarea traficului de rețea pentru a observa activități neobișnuite. De exemplu, folosind un analizator de pachete precum Wireshark, poți monitoriza traficul dintre utilizatori și servere pentru a identifica modificări suspecte. Dacă, spre exemplu, traficul pare a fi redirecționat printr-o altă adresă IP sau un dispozitiv anume generează un volum mare de date, acest lucru poate semnala o posibilă interceptare. Un alt indicator poate fi o creștere neobișnuită a traficului pe anumite protocoale de rețea.

Un al doilea pas în detecție este activarea alarmei de securitate și a sistemelor de detecție a intruziunilor (IDS). Aceste sisteme sunt configurate să alerteze administratorii de rețea atunci când detectează modificări neobișnuite, cum ar fi o schimbare a adresei MAC a unui dispozitiv. De exemplu, dacă un atacator încearcă să se conecteze ca un dispozitiv autorizat și încearcă să imite adresa acestuia, alarmele de securitate pot detecta diferențele și semnala prezența unui dispozitiv nesigur. Un sistem IDS, precum Snort, poate fi configurat să detecteze pachete neobișnuite și să alerteze în timp real despre activități care par specifice unui atac MITM.

2. Izolarea incidentului

Izolarea unui atac MITM este crucială pentru a preveni extinderea acestuia la alte dispozitive și utilizatori din rețea. Un prim pas este deconectarea dispozitivelor compromise. De exemplu, dacă un laptop arată semne de activitate anormală, deconectează-l imediat din rețea pentru a analiza posibilele cauze. De asemenea, acest lucru împiedică atacatorul să intercepteze mai multe date de la acel dispozitiv.

Un alt pas este segmentarea rețelei, adică împărțirea rețelei în mai multe sub-rețele izolate, numite VLAN-uri (Virtual Local Area Networks). Dacă există un atac MITM într-un segment, segmentarea permite limitarea accesului atacatorului doar la acea zonă. De exemplu, într-o rețea de companie, poți izola serverele și bazele de date într-un VLAN, astfel încât traficul compromis să nu aibă acces la aceste resurse critice. Segmentarea limitează expunerea la atac și poate reduce semnificativ pagubele.

3. Identificarea vectorului de atac

Pentru a remedia complet un atac MITM și a înțelege cum a avut loc compromiterea inițială, este important să identifici vectorul de atac, adică modul exact prin care atacatorul a obținut acces la rețea. Un prim pas este analiza logurilor de acces și a activității din rețea. În logurile de acces pot apărea detalii despre încercări repetate de conectare, autentificări din locații neobișnuite sau în afara orelor normale de lucru. De exemplu, dacă vezi că un utilizator autentificat de obicei într-o anumită locație încearcă acum să se conecteze dintr-o locație diferită, ar putea fi un semn că atacatorul a preluat contul utilizatorului.

De asemenea, este esențial să verifici dacă există aplicații vulnerabile sau dispozitive IoT care ar fi putut permite atacul. Multe atacuri MITM exploatează dispozitive conectate, cum ar fi imprimantele sau camerele de securitate, care nu au software actualizat. Dacă găsești un dispozitiv cu firmware vechi, este posibil ca acesta să fi fost vectorul inițial al atacului. Identificarea acestor vulnerabilități îți permite să izolezi mai bine incidentul și să iei măsuri de prevenire pe viitor.

4. Remedierea atacului

După ce ai identificat vectorul de atac și ai izolat incidentul, este important să iei măsuri pentru a opri complet atacul și a restabili siguranța rețelei. Resetarea conexiunilor de rețea este un pas critic în remedierea atacului. De exemplu, reconfigurarea conexiunilor VPN și reautentificarea utilizatorilor împiedică atacatorul să continue interceptarea datelor. Dacă un atacator a interceptat traficul dintre birou și un server extern, reconectarea prin VPN cu reconfigurarea parametrilor de securitate va bloca accesul acestuia.

Un alt pas important este actualizarea certificatelor și cheilor de criptare. Dacă un atacator a avut acces la date criptate, este posibil ca acele certificate și chei să fi fost compromise. Într-o companie, de exemplu, este necesar să reînnoiești toate certificatele TLS folosite pentru aplicațiile interne, pentru a asigura confidențialitatea și securitatea traficului. În plus, trebuie să actualizezi dispozitivele și software-ul compromis, reinstalând sistemele de operare afectate sau aplicând cele mai recente actualizări de securitate. Aceasta elimină orice malware sau configurații compromițătoare.

5. Recuperarea și restaurarea

După ce atacul a fost remediat, trebuie să te asiguri că rețeaua și utilizatorii pot reveni la o stare de funcționare normală, dar securizată. În primul rând, revalidează autentificările utilizatorilor. Acest lucru poate implica schimbarea parolelor și utilizarea autentificării multifactor, pentru a preveni accesul neautorizat. De exemplu, toți utilizatorii trebuie să-și reautentifice accesul și să folosească un cod de confirmare prin telefon sau un dispozitiv extern.

Un alt pas este monitorizarea intensivă post-incident. Continuă să monitorizezi activitatea rețelei pentru a te asigura că nu au rămas urme ale atacului sau puncte de acces neautorizate. Aceasta poate include loguri extinse și analize automate pentru o perioadă de timp, pentru a detecta activități suspecte. Documentarea incidentului este, de asemenea, un pas esențial pentru a învăța din experiență. Realizează un raport detaliat al incidentului, al pașilor urmați și al vulnerabilităților exploatate, pentru a ajusta planurile de securitate și a preveni incidente similare.

Plan de acțiune pentru prevenirea atacurilor MITM și întărirea securității

1. Criptarea traficului de rețea

Pentru a reduce riscul unui atac MITM, toate comunicațiile din rețea trebuie să fie criptate. Folosirea TLS pentru comunicații securizate este o măsură obligatorie. De exemplu, dacă ai un site web al companiei sau aplicații de tip SaaS, asigură-te că acestea folosesc HTTPS pentru ca atacatorii să nu poată intercepta datele. La fel, pentru rețelele externe sau publice, VPN-urile oferă un tunel criptat, care protejează datele transmise. De exemplu, angajații care lucrează de la distanță pot folosi un VPN pentru a se conecta în siguranță la rețeaua companiei.

2. Implementarea autentificării multifactor (MFA)

Implementarea acestei idei de autentificare adaugă încă un strat de securitate, cerând astfel utilizatorului să se conecteze prin două sau mai multe acte de identitate înainte de a accesa sistemele. Pe lângă autentificarea normală de timp username și parolă, este necesară introducerea unui cod generat de o aplicație care se schimbă la o diferență de câteva secunde. Este esențial să existe și o parolă puternică, dar este important de reținut că securitatea nu depinde doar de complexitatea parolei. Autentificarea multifactor (MFA) este un strat suplimentar de securitate care poate opri atacatorii chiar dacă au obținut datele de autentificare. De exemplu, autentificarea în doi pași (2FA) folosește un cod trimis pe telefonul utilizatorului sau un cod dintr-o aplicație de autentificare. În cazul unui atac MITM, acest lucru face ca atacatorul să nu poată accesa contul fără acest cod, reducând semnificativ riscul de acces neautorizat. MFA poate include și factori de autentificare biometrică, de exemplu scanarea amprentelor digitale sau recunoașterea facială, pentru adăugarea unui nivel suplimentar de protecție.

3. Monitorizarea continuă a rețelei

Monitorizarea continuă a rețelei este crucială pentru detectarea rapidă a unui atac MITM. Implementarea unui Sistem de Detectare a Intruziunilor (IDS) poate semnaliza comportamente neobișnuite în rețea, cum ar fi volumul ridicat de trafic de la un dispozitiv care nu generează de obicei atât de multe date. De exemplu, dacă un atacator folosește un dispozitiv compromis pentru a intercepta date, un IDS poate

identifica acest trafic suspect și trimite o alertă echipei de securitate. Totodată, un Sistem de Gestionare a Evenimentelor și Informațiilor de Securitate (SIEM), care colectează și corelează alertele din întreaga rețea, poate evidenția rapid activitățile suspecte, oferind echipei o imagine de ansamblu pentru a lua măsuri rapide și eficiente în caz de incident.

4. Educația utilizatorilor

Educația utilizatorilor este esențială pentru prevenirea atacurilor MITM, deoarece mulți atacatori profită de greșelile umane. Trainingurile de securitate cibernetică îi ajută pe utilizatori să fie conștienți de riscuri și să ia măsuri de precauție, cum ar fi evitarea rețelelor publice nesecurizate sau recunoașterea semnalelor de alertă, precum mesajele de tip „conexiune nesigură”. De asemenea, simulările de atacuri îi pregătesc pentru situații reale, arătându-le cum să reacționeze în mod corespunzător și să raporteze incidentele de securitate. Aceasta face ca utilizatorii să devină o verigă puternică în lanțul de apărare al organizației, reducând considerabil riscul de atacuri reușite.